Android 隐私检测系统
全阶段实验总汇报

从隐私政策文本分析到知情权、同意权、访问权动态验证

李禹江，张博涵，蒋兴宇

我的刀盾队

2026-06-28

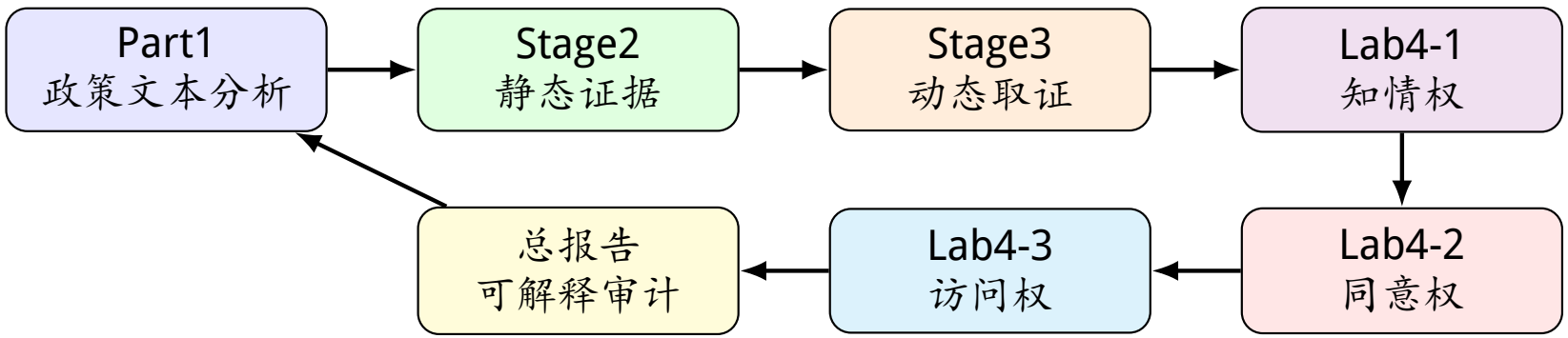
目录

1. 总览：实验目标与演进路线
2. Part1：隐私政策文本分析
3. 系统设计：证据驱动的隐私审计
4. Stage3：动态取证与工程实现
5. Lab4-1：知情权审计
6. Lab4-2：同意权与开关有效性
7. Lab4-3：访问权与个人信息副本
8. 综合结果与案例串联
9. 方法反思与系统局限
10. 结论与后续工作

总目标：把隐私政策承诺变成可验证证据

- **起点**：对 Android App 隐私政策做句级分析，识别用户权利、执行路径、数据对象与风险。
- **中期**：从 LLM 判断升级为证据驱动的规则引擎，构建政策声明、静态分析、动态取证、知识库的统一证据包。
- **后期**：围绕 Lab4 三项权利开展实验：知情权、同意权、访问权。
- **最终形态**：形成一套可复现的 Android 隐私检测系统，输出可追溯报告，而不是只给出黑盒结论。

全阶段路线图



研究路径从「文本中是否声明」逐步推进到「系统是否真实采集」「开关是否生效」「用户是否能拿到副本」。

本次总汇报覆盖范围

阶段	核心内容	关键结果
Part1	隐私政策句级 Prompt、权利识别、路径抽取	23 App，9639 句
系统设计	证据包、规则引擎、知识库、统一 CLI	Lab4 流水线成型
Lab4-1	政策声明 vs 多源观测，验证知情权	9/9 成功；90 一致，41 高风险
Lab4-2	关闭隐私开关前后网络/Tracker 对比	15/15 有结果；3 pass；7 款关后仍传
Lab4-3	运行时采集 vs 用户副本字段	5 款人工副本审核；剩余待补全

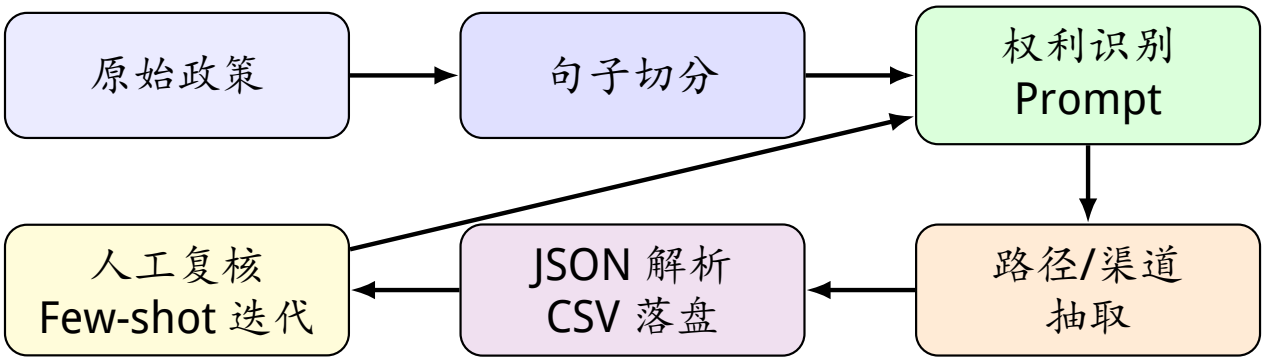
实验对象从 23 App 收敛到重点样本

- **文本分析阶段**：23 款 App，覆盖招聘、金融、社交、健康、本地生活等场景。
- **Lab4-1 主样本**：Keep、小红书、支付宝、LOFTER、智联招聘、世纪佳缘、好大夫医生版、东方财富、小荷健康。
- **Lab4-2/3 扩展样本**：增加钓鱼人、快看漫画、韭研公社等，形成 15 App 动态验证批次。
- **选择依据**：政策文本中存在可执行路径、具备隐私开关或副本入口、能在模拟器/真机中完成基本导航。

Part1 实验问题

- 隐私政策是否明确说明用户享有哪些权利？
- 是否给出 App 内路径、网页、邮箱、客服、处理时限等可执行方式？
- 权利文本是否能被结构化为后续自动化验证任务？
- 重点识别四类权利：知情权、同意/撤回同意权、访问/查询/复制权、删除权。

Part1 处理流水线



Prompt 输出结构

- `right_claim`：是否出现权利或知情声明。
- `right_types`：同意、访问复制、删除、注销等枚举标签。
- `method_claim`：是否给出路径、渠道或处理时限。
- `path_text`：最具体的执行路径或联系方式。
- `target_data`：权利指向的数据对象。
- `app_test_candidate`：是否适合后续 Appium/网页/人工验证。

设计重点：区分「有权利声明」与「能否实际操作」，为动态验证阶段提供入口候选。

Part1 数据规模

指标	数量	含义
App 数	23	覆盖招聘、金融、健康、社交等多类应用
政策句子	9639	对隐私政策逐句切分后得到的分析单元
送标候选	4371	需要模型或人工进一步判断的重点句子
权利声明正例	5180	命中 right_claim 的句子级标签
执行方式正例	1053	命中 method_claim，约 10.9%

Top 应用句级统计

应用	句数	right	method	candidate	method 率
51Job	2674	826	213	207	8.0%
360 借条	697	326	47	47	6.7%
平安证券	608	318	75	75	12.3%
中国工商银行	387	249	35	35	9.0%
好大夫医生版	386	167	26	26	6.7%
智联招聘	372	263	74	74	19.9%
Soul	347	234	42	42	12.1%
58 同城	346	215	46	46	13.3%
合计	**9639**	**5180**	**1053**	**1046**	**10.9%**

观察：权利声明文本很多，但真正给出可执行路径的句子占比明显更低。

访问复制权的细分价值

类型	含义	后续验证方式
copy	能下载、导出、保存为个人信息副本	可检查副本字段是否覆盖运行时采集数据
non_copy	只能在界面内查看个人信息	适合用 Appium 截图或人工复核
unknown	只声明查询/复制权，但未说明形态	需要人工寻找入口或联系渠道

这一细分直接支撑 Lab4-3：判断 App 是否真正提供可核验的个人信息副本。

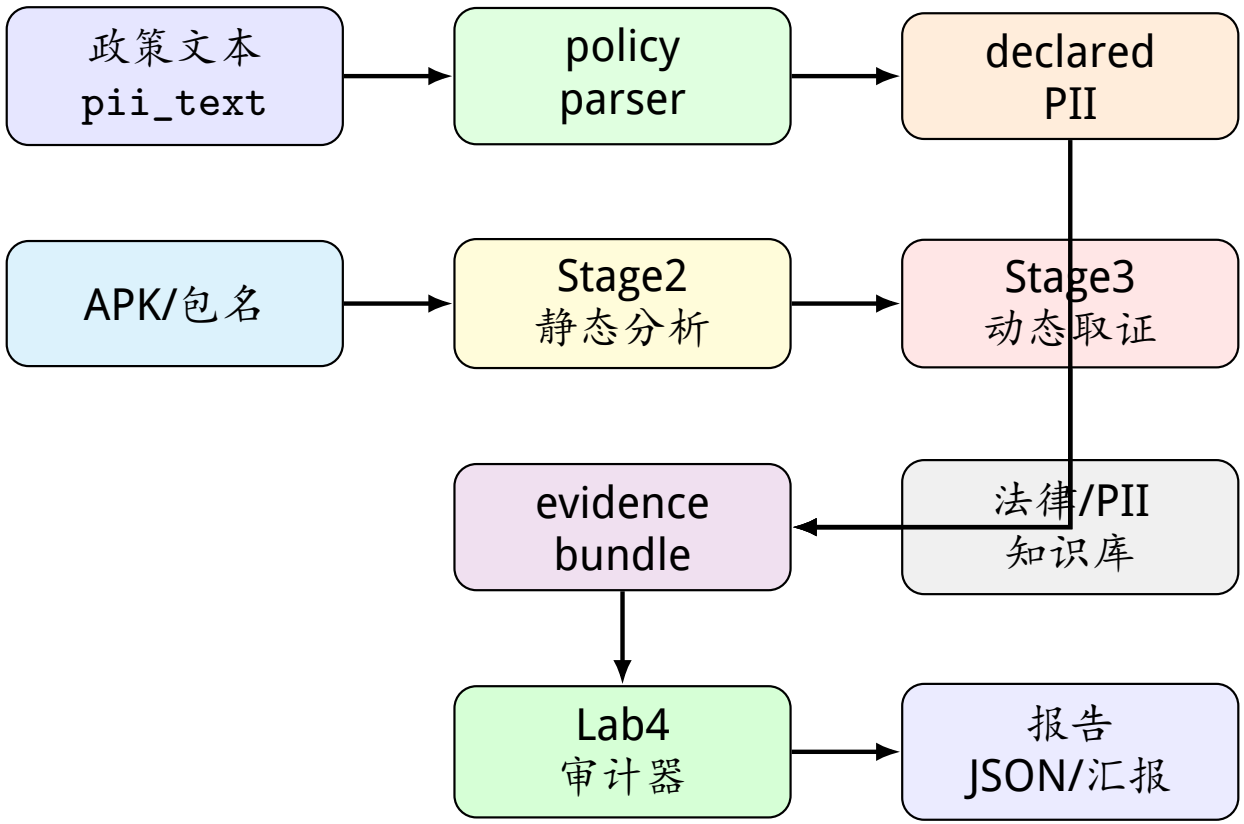
Part1 阶段结论

- LLM 适合作为句级结构化抽取器，尤其适合从自然语言政策中抽取路径、渠道和目标数据。
- 直接让 LLM 输出合规 verdict 风险较高，因此后续改为「LLM 抽取 + 规则引擎判定 + 证据溯源」。
- 句级结果成为动态验证的任务来源：哪些 App 有路径、哪些权利适合测试、哪些条目需要人工复核。

为什么从 LLM 判定转向证据包

方面	早期思路	最终实现
判定主体	LLM 直接输出合规结论	规则引擎 + 可追溯证据
证据来源	主要依赖文本	政策、静态、动态、历史结果、知识库合并
动态验证	泛化 UI 探索	政策路径驱动 + 分 App 适配
工程形态	脚本分散	统一 CLI、batch、job id、manifest

系统总体架构


政策文本
pii_text
policy
parser
declared
PII
APK/包名
Stage2
静态分析
Stage3
动态取证
evidence
bundle
法律/PII
知识库
Lab4
审计器
报告
JSON/汇报

端到端 Pipeline

1. **政策解析**：policy_parser 将政策文本转为 declared_pii[]。
2. **静态分析**：Exodus + Androguard 抽取 SDK、权限、敏感 API 等技术信号。
3. **动态取证**：Appium 导航隐私路径，Frida/mitm 采集运行时证据。
4. **证据合并**：evidence_loader 与知识库统一类型、别名和来源。
5. **权利审计**：lab4-1-audit、lab4-2-audit、lab4-3-audit 生成报告。
6. **批量复现**：按 App 列表与 job id 产出 batch summary 和 manifest。

核心模块划分

ingestion

- `policy_parser`
- `evidence_loader`
- `privacy_knowledgebase`

analyzers

- `compare_engine`
- `consent_compare`
- `access_compare`

dynamic

- `appium_runner`
- `element_tap`
- `frida_collector`
- mitm flow analyzer

reporting

- Lab4 报告生成
- batch summary
- 可视化与 PPT

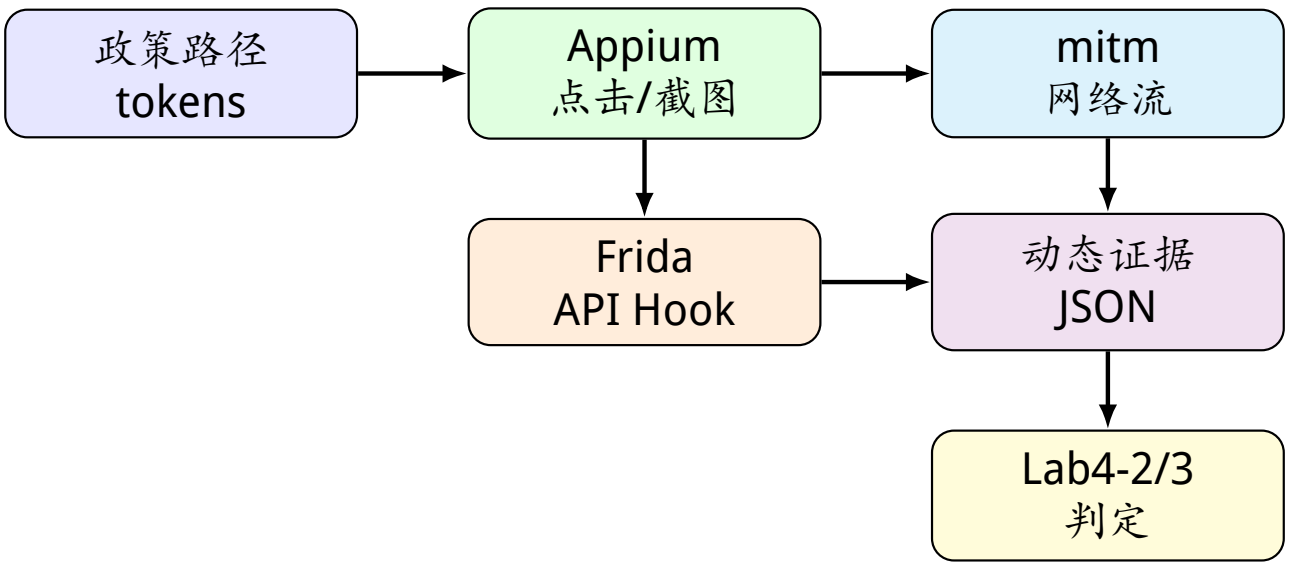
三项权利的系统化定义

实验	核心问题	证据组合
Lab4-1 知情权	政策声明的 PII 类型是否覆盖实际观测？	政策声明 + 静态 + 动态 + oldsrc + KB
Lab4-2 同意权	用户关闭开关后，相关采集/传输是否停止？	before/after 动态证据 + mitm Tracker/PII 流量
Lab4-3 访问权	用户副本是否覆盖运行时采集和政策声明字段？	政策声明 + 运行时观测 + 个人信息副本

Stage3 单次动态验证流程

1. **解析路径**：隐私政策 → `navigation_paths[]`，得到可点击 token 序列。
2. **并行取证**：mitm 抓包、Frida Hook、Appium 真机导航同时运行。
3. **UI 点击**：按路径逐 token 点击；失败时滚动、侧栏、头像、齿轮、LLM 兜底。
4. **证据落盘**：输出 `dynamic_evidence.json`、`mitm_flows.json`、`network_evidence.json`。

Stage3 数据流


政策路径
tokens
Appium
点击/截图
mitm
网络流
Frida
API Hook
动态证据
JSON
Lab4-2/3
判定

实验环境

- **系统环境**：Windows + MuMu/ADB + Appium 4723。
- **动态 Hook**：Frida client 与 frida-server 版本匹配，覆盖 IMEI、OkHttp、PAPI 等层次。
- **网络观测**：mitmproxy 作为 Lab4-2/3 主轨，识别 Tracker、PII 字段和 before/after 差异。
- **批次管理**：通过 job id 区分 Lab4-1、Lab4-2、Lab4-3 与 before/after 采集结果。

分 App UI 自动化适配经验

App	适配要点
世纪佳缘	底部 Tab 文案为 " 我"，需按 bounds 点最右 Tab，避免误点「推荐」。
小荷健康	设置无文字，UserPage 右上角最右侧齿轮为设置，左侧为扫一扫。
支付宝	需精确匹配「我的」，避免宽泛「我」；部分设置入口在 H5/WebView 容器中。
其他 App	政策路径 token + 关键词/头像/齿轮兜底，必要时加入滚动与候选排序。

Frida 三层 Hook 设计

层次	目标	作用
IMEI/设备标识层	TelephonyManager 等敏感 API	捕获设备标识读取行为
OkHttp 网络层	请求 URL、header、body	观察 PII 是否进入网络请求
PAPI 目标层	剪贴板、联系人、位置等 API	补充隐私类型的 API 级证据

Reactor 串行化 Frida 回调，避免异步消息并发导致证据乱序。

Frida 工程卡点

- **Spawn vs Attach**：部分 App 对 spawn 注入敏感，attach 又可能错过早期 API 调用。
- **防注入/反调试**：部分应用存在检测、加固或动态类加载，导致 Hook 脚本加载成功但无有效事件。
- **进程匹配**：App 多进程、短生命周期服务和 WebView 容器会造成找不到进程或挂错进程。
- **连接稳定性**：长时间 Appium 操作中 Frida 连接可能断开，需要重连和事件健康检查。

为何引入 mitm 作为网络主轨

- OkHttp Hook 覆盖不到所有网络栈，且容易受混淆、加固、动态加载影响。
- mitm 从设备出口观察 HTTP(S) 流量，更适合做 before/after 对比。
- 对 Lab4-2 来说，关开关后 Tracker 或 PII 仍传输是更直接的同意权风险信号。
- 对 Lab4-3 来说，mitm 可补充「运行时确实上传了哪些 PII」的传输级证据。

动态验证手段分工

手段	强项	本批角色
Appium UI	政策路径导航、截图、关键词探测	主轨：驱动隐私设置页到达
mitm 网络	全进程 HTTP 污点、Tracker 识别、开关前后对比	主轨：Lab4-2/3 核心证据
Frida Hook	API 级采集、调用栈、IMEI 精准 Hook	辅助：补 API 证据，受 Spawn/Attach 限制
静态 + KB	APK 信号、法律知识库推断	Lab4-1 多源合并

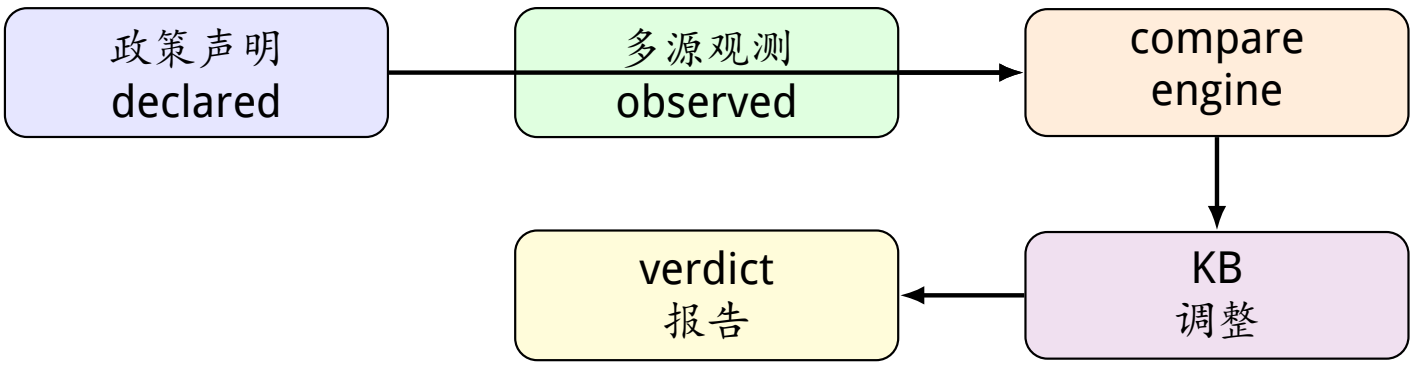
Lab4-1 核心问题

问题定义

应用隐私政策中声明收集/使用的个人信息类型，是否覆盖静态分析、动态取证、历史审计与知识库中观测到的个人信息类型？

- 声明且观测到：`consistent`
- 未声明但观测到：`inconsistent_high_risk`
- 声明但未观测到：`declared_not_observed`

Lab4-1 判定逻辑



每条 verdict 记录 `sources[]` / `provenance`，答辩时可以说明证据来自 static、dynamic、oldsrc 还是 KB。

Lab4-1 样本与批次

- **样本数**：9 款 App。
- **样本**：Keep、小红书、支付宝、LOFTER、智联招聘、世纪佳缘、好大夫医生版、东方财富、小荷健康。
- **证据来源**：政策声明、Stage2 静态、Stage3 动态、oldsrc 历史结果、PII 知识库。
- **批量结果**：9/9 成功生成知情权审计报告。

Lab4-1 全样本 Verdict 合计

Verdict	条数
consistent	90
inconsistent_high_risk	41
declared_not_observed	6

- 一致：政策声明有，合并证据也有。
- 高风险：证据有，但政策声明不足。
- 未观测：政策声明有，但当前证据链未捕获。

Lab4-1 分 App 数据表

App	声明	观测	一致	高风险	未观测	
Keep	11	18	11	5	0	
小红书	12	15	10	4	1	
支付宝	11	16	10	5	1	
LOFTER	10	16	10	4	2	
智联招聘	13	17	12	5	0	
世纪佳缘	12	14	10	4	2	
好大夫医生版	11	13	8	4	1	
东方财富	10	16	9	5	2	
小荷健康	11	17	10	5	0	

Lab4-1 典型发现：观测类型多于声明类型

- 多数 App 的 observed_count 大于 declared_count。
- 原因包括：静态 SDK/权限信号、历史审计结果、知识库推断、动态路径可行性证据并入观测集。
- 这类差异会转化为 inconsistent_high_risk，代表「技术侧或知识库侧有信号，但政策未充分声明」。
- 汇报时需要明确区分证据来源，避免笼统表述为「Frida 抓到了」。

declared_not_observed 明细

1. **好大夫医生版**：account_info，受限于应用需要资格认证，无法动态验证。
2. **世纪佳缘**：biometric_info，静/动/oldsrc/KB 均未并入。
3. **东方财富**：log_info，声明有，观测列表无此项。
4. **世纪佳缘**：log_info，声明有，观测列表无此项。
5. **支付宝**：clipboard，政策已写，合并证据未列出。
6. **智联招聘**：clipboard，政策已写，合并证据未列出。

这类结果不直接说明违规，而说明当前证据链对该声明类型尚未覆盖。

Lab4-1 类型并集与交集

	并集（至少 1 款 App 出现）	**交集（9 款 App 均有）**
声明	账号、AndroidID、生物识别、剪贴板、通讯录、身份、IMEI、IP、位置、日志、MAC、未成年人、权限、手机号、画像（15 类）	账号、AndroidID、身份、IMEI、IP、位置、手机号（7 类）
观测	上列 + 权利、SDK、安全（18 类）	AndroidID、通讯录、IMEI、IP、位置、MAC、权限、手机号、画像、权利、安全（11 类）
高风险	剪贴板、通讯录、未成年人、权限、画像、权利、SDK、安全（8 类）	权利、安全（2 类）
未观测	账号、生物识别、剪贴板、日志（4 类）	无

Lab4-1 阶段结论

- 知情权审计已形成稳定批量流程，9 款 App 均能输出可解释报告。
- 最有价值的结果是 41 条 高风险 不一致：可以指向政策未充分声明的具体个人信息类型。
- 6 条 中风险 未观测反映证据覆盖不足，也提示需要继续强化动态路径和副本采集。
- 系统已具备「结论 + 证据来源 + 风险解释」的答辩能力。

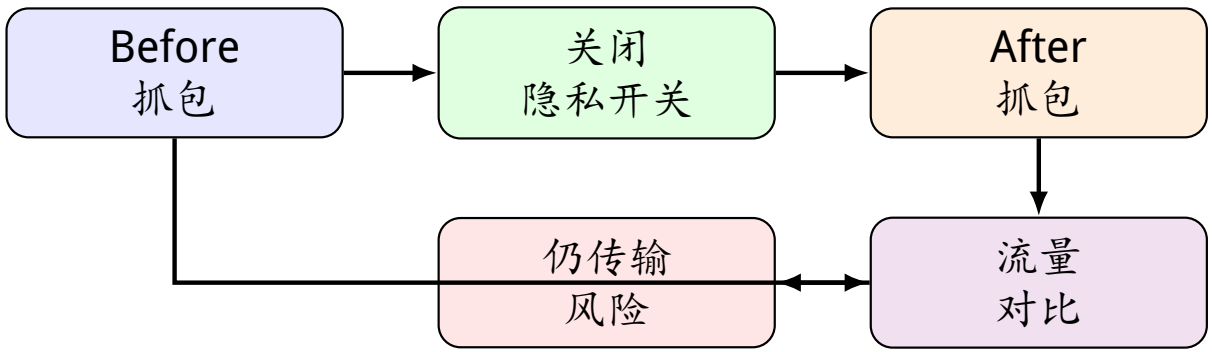
Lab4-2 核心问题

问题定义

当用户关闭个性化推荐、广告、第三方共享或相关隐私开关后，App 是否仍继续向服务端或第三方 Tracker 传输相关个人信息？

- **before**：默认或开启状态下进行路径导航与抓包。
- **after**：关闭隐私开关后重复同样流程。
- **主判定**：对比 mitm 流量中的 Tracker 命中、PII 字段和仍传输数量。

Lab4-2 实验管线



Lab4-2 从早期 Frida 主轨调整为 mitm 主轨，因为网络层 before/after 对比更稳定、更直接。

Lab4-2 判定口径

状态	含义
pass	关闭开关后未观察到相关 Tracker/PII 继续传输，或流量明显下降到可接受范围。
review_needed	关闭后仍存在 PII 字段或 Tracker 命中，需要人工确认是否与开关语义相关。
strong case	关闭后仍有明确第三方 SDK Tracker 或敏感字段传输，是答辩展示重点。

Lab4-2 本批总体结果

- **样本**：15 款 App。
- **批量状态**：15/15 进入 pass 3 / review_needed 等结果分类。
- **pass**：Keep、支付宝、韭研公社。
- **关后仍传问题**：7 款 App 存在关闭后仍传输 PII 或 Tracker 的现象。
- **强案例**：钓鱼人、好大夫、快看漫画、世纪佳缘。

Lab4-2 典型网络对比

App	before 流	after 流	PII 命中	关后仍泄漏
小荷健康	272	312	58→58	无 SDK Tracker；仍有 PII 传输
快看漫画	162	206	21→17	SDK Tracker（Umeng/百度/个推）
世纪佳缘	234	276	38→38	SDK Tracker（百度/Bugly）
钓鱼人	82	83	30→33	SDK Tracker（Umeng/Bugly/百度）
Keep	67	1	4→0	否（pass）

Lab4-2 强案例解读

- **钓鱼人**：关闭后 PII 命中从 30 增至 33，同时仍有 Umeng/Bugly/百度 Tracker。
- **快看漫画**：关闭后流量增加，PII 命中仍为 17，且保留多类第三方 Tracker。
- **世纪佳缘**：关闭前后 PII 命中均为 38，百度/Bugly 仍存在。
- **Keep**：关闭后流量从 67 降至 1，PII 命中降为 0，是同意权开关较有效的对照样本。

Lab4-2 的证据强度与局限

证据强度

- before/after 同流程对比。
- 网络出口层直接观测。
- 可定位 Tracker 公司和字段。

局限

- 开关语义与具体传输字段需要人工确认。
- 证书钉扎或私有协议会降低 mitm 覆盖。
- 低流量 App 需加长抓包窗口。

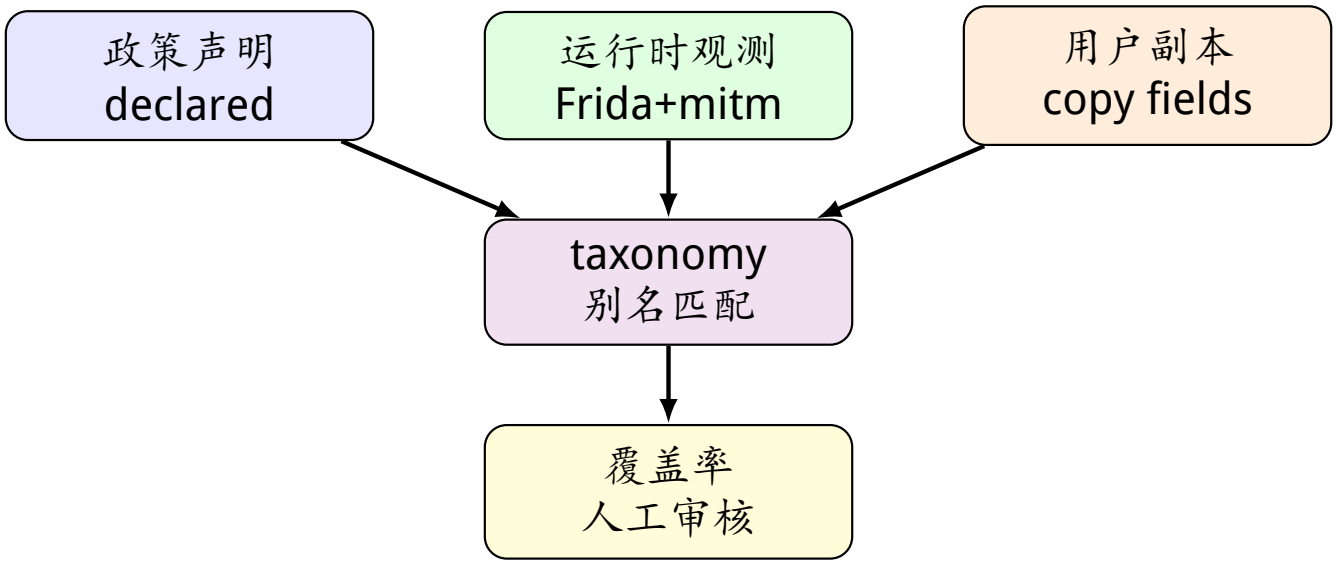
Lab4-3 核心问题

问题定义

用户能否访问、查询、复制或导出 App 收集的个人信息？导出的副本字段是否覆盖政策声明和运行时实际采集/传输的数据？

- **政策侧**：声明用户可查询/复制哪些数据。
- **运行时侧**：Frida + mitm 观测实际采集/传输字段。
- **副本侧**：人工导出或页面查看的个人信息副本字段。

Lab4-3 实验管线


政策声明
declared
运行时观测
Frida+mitm
用户副本
copy fields
taxonomy
别名匹配
覆盖率
人工审核

Lab4-3 人工审核结果

App	副本所含个人信息类型
世纪佳缘	生物识别信息、手机号、账号/账户信息、身份信息
小荷健康	手机号、账号/账户信息、身份信息
智联招聘	手机号、身份信息、账号/账户信息、位置信息
支付宝	手机号、身份信息
东方财富	手机号、账号/账户信息、身份信息

Lab4-3 结果解读

- 已完成 5 款 App 的人工副本字段审核，能展示副本中包含哪些个人信息类型。
- 副本字段多集中于手机号、账号/账户信息、身份信息，部分 App 覆盖位置或生物识别信息。
- 与运行时 mitm/Frida 观测结合后，可进一步判断「实际传输的数据」是否也能在副本中被用户访问。
- 当前仍需补全剩余 App 副本导出，并扩充 taxonomy 别名，提高自动匹配覆盖率。

Lab4-3 与 Lab4-1/2 的关系

- Lab4-1 回答「政策有没有说清楚」。
- Lab4-2 回答「用户关闭后是否还继续传」。
- Lab4-3 回答「用户能否查到/拿到已经被收集的数据」。
- 三者共同构成从告知、控制到访问的完整隐私权利验证链。

全阶段关键数字

阶段	数字	说明
Part1	23 App / 9639 句	完成隐私政策句级权利识别与路径抽取
Part1	1053 条 method 正例	仅约 10.9% 句子给出执行方式
Lab4-1	9/9 成功	知情权批量审计稳定输出
Lab4-1	90 / 41 / 6	一致 / 高风险不一致 / 声明但未观测
Lab4-2	15 App	3 个 pass，7 款存在关后仍传问题
Lab4-3	5 款副本审核	已形成人工字段覆盖结果，待扩展自动匹配

一条完整审计链如何形成

1. **文本侧**：Prompt 从政策中抽取权利、路径、目标数据。
2. **技术侧**：Stage2/Stage3/mitm 生成静态与动态证据。
3. **知识侧**：PII taxonomy 和法律知识库统一别名、补充可行证据。
4. **判定侧**：Lab4-1/2/3 分别输出知情、同意、访问三个角度的 verdict。
5. **解释侧**：每个结论保留来源和证据字段，支持人工复核与答辩追问。

案例串联：Keep

- **Lab4-1**：声明 11 类、观测 18 类，一致 11、高风险 5、未观测 0。
- **高风险类型**：剪贴板、通讯录、权利、SDK、安全。
- **Lab4-2**：关闭后流量 67→1，PII 命中 4→0，判为 pass。
- **意义**：Keep 是同意权开关有效的正向对照，但知情权侧仍存在政策覆盖不足风险。

案例串联：世纪佳缘

- **Lab4-1**：声明 12 类、观测 14 类，一致 10、高风险 4、未观测 2。
- **未观测类型**：生物识别、日志；其中生物识别受真实认证流程限制。
- **Lab4-2**：关闭前后 PII 命中 38→38，仍有百度/Bugly Tracker。
- **Lab4-3**：副本含生物识别信息、手机号、账号/账户信息、身份信息。
- **意义**：适合展示三项权利如何在同一 App 上互相印证。

案例串联：智联招聘

- **Part1**：method 率 19.9%，说明政策中有较多可执行路径，适合动态验证。
- **Lab4-1**：声明 13 类、观测 17 类，一致 12、高风险 5、未观测 0。
- **Lab4-3**：副本含手机号、身份信息、账号/账户信息、位置信息。
- **意义**：招聘类 App 的个人信息类型较多，访问权副本和政策声明的匹配尤其重要。

案例串联：支付宝

- **UI 特例**：部分隐私入口在 H5/WebView 容器中，路径定位比原生页面复杂。
- **Lab4-1**：声明 11 类、观测 16 类，一致 10、高风险 5、未观测 1。
- **未观测类型**：剪贴板。
- **Lab4-2**：本批结果中为 pass 样本。
- **Lab4-3**：副本含手机号、身份信息。

当前系统的优势

- 从文本、静态、动态、网络、副本多个角度构造证据链。
- 规则引擎结论可追溯，比纯 LLM verdict 更适合审计场景。
- Appium + mitm 的组合让同意权实验具备可复现的 before/after 对比。
- 批量报告、job id 与 manifest 让实验过程可以复查、增量补跑。

当前系统的局限

- Frida 运行时 Hook 仍受 spawn/attach、加固、多进程、连接稳定性影响。
- mitm 无法覆盖所有证书钉扎、私有协议或加密载荷。
- Appium UI 路径依赖具体版本页面，H5/WebView 和无障碍文本缺失会增加失败率。
- Lab4-3 的副本采集成本较高，仍需要人工导出和 taxonomy 别名维护。

判定伦理：高风险不一致为何更重要

- 「政策声明了但未观测到」可能只是本次证据未覆盖，不能直接说明应用没有采集。
- 「观测到了但政策未声明」意味着用户难以从政策中获知相关处理行为，知情权风险更强。
- 因此系统将 `inconsistent_high_risk` 作为重点输出，并保留具体证据来源。
- 这与监管关注的「未明示收集目的、方式、范围」「未公开第三方 SDK」等主题一致。

从课程实验到可用审计工具的差距

方面	已完成	仍需提升
文本抽取	句级结构化、路径候选、few-shot 迭代	构建人工金标集和模型一致性评估
知情权	批量稳定，证据可追溯	更精细地区分技术证据与 KB 推断
同意权	mitm before/after 可用	开关语义绑定、低流量窗口、证书钉扎处理
访问权	5 款副本人工审核	扩展副本导出、自动字段匹配、覆盖率计算

总阶段性结论

- 本实验已经从最初的隐私政策文本分析，发展为覆盖知情权、同意权、访问权的综合检测系统。
- Lab4-1 是当前最稳定的主实验：9 款 App 批量成功，输出 90 条一致、41 条高风险不一致、6 条声明未观测。
- Lab4-2 通过 mitm 主轨完成 15 App 开关前后对比，发现 7 款存在关后仍传问题，并保留多个强案例。
- Lab4-3 已完成 5 款副本人工审核，证明访问权验证路径可行，但仍需要补全样本和自动匹配。

后续工作

1. **Frida 加固**：借鉴 spawn gating，扩展 tier 探针，稳定 API 级证据采集。
2. **mitm 增强**：处理证书钉扎、延长低流量窗口、补充 Tracker 规则库。
3. **Lab4-2 精化**：将隐私开关语义与字段/Tracker 分类绑定，减少人工解释成本。
4. **Lab4-3 补全**：导出剩余 App 副本，扩充字段别名，提升自动覆盖率。
5. **评测体系**：建立人工金标集，对 Prompt、规则引擎和动态路径分别评估准确性。

答辩展示建议

- 主线按「文本承诺 → 技术证据 → 三项权利」展开。
- 重点展示 Lab4-1 的可追溯判定和 Lab4-2 的 before/after 强案例。
- 对局限保持诚实：Frida 不是当前主证据，mitm 和人工副本审核才是后期实验主轨。
- 选 1–2 个 App 做全链路案例，例如世纪佳缘或 Keep。

感谢聆听